Джафарлі. Рев`ю “Enhancing Microservice Security”

Фарід Джафарлі · Advanced Security Architecture and Engineering · Наукова публікація 2

1. Вступ

Стаття «Enhancing Microservice Security Through Vulnerability-Driven Trust in the Service Mesh Architecture» (Rami Alboqmi, Rose F. Gamble; University of Tulsa; Sensors, 2025) вказує на прогалину в service mesh: mTLS автентифікує сервіси, але не бачить вразливих сторонніх бібліотек усередині них. Мета авторів: автоматично й безперервно оцінювати довіру до кожного мікросервісу за вразливостями його образу. Це дослідницька робота (PoC), що розширює попередню модель авторів SMAAC.

2. Методологія

У площині керування SMAAC працюють TIS (обмін даними про загрози), runtime trust evaluator (RTE) і модуль APG, що генерує політики доступу залежно від рівня довіри; sidecar-проксі є точками застосування політик (PEP). Замість фіксованих 100 % довіру тепер обчислює цикл: TIS через Kubernetes SDK знаходить запущені образи, Trivy сканує їх (low, medium, high, critical). RTE рахує Vul як зважену суму CVSS за категоріями (ваги від 0,1 для low до 0,4 для critical задає ризик-команда), а довіру як TM = 100 − (Vul − MinVul) / (MaxVul − MinVul) × 100, тобто min-max-нормалізацію відносно всіх сервісів. TIS поширює TM, а поки образ використовується, оцінка повторюється.

Експеримент: Train Ticket (понад 40 мікросервісів) на Docker, Kubernetes та Istio, п’ять сервісів у версіях 0.0.4 і 1.0.0, навантаження Locust на 100 користувачів.

3. Результати

У версії 0.0.4 admin-order мав 65/174/163/76 вразливостей рівнів low/medium/high/critical: Vul = 120,6, TM = 94,27. Мінімальний Vul (27,7) мав news (TM = 100), максимальний (1649,6) мав voucher (TM = 0). У версії 1.0.0 Vul voucher знизився до 1073,2, і TM зріс до 6,17. У ticket-office Vul зріс з 725,6 до 1062,7, а TM упав із 57,00 до 7,11. Без механізму чотири з п’яти сервісів оброблялися швидше ніж за 100 мс, із ним за кілька секунд, що для PoC прийнятно.

4. Ключові інсайти

- mTLS підтверджує лише ідентичність сервісу. Сервіс із вразливою бібліотекою лишається плацдармом для атаки, тому в Zero Trust-архітектурах я враховуватиму стан вразливостей у рішенні про доступ: як атрибут для OPA (Envoy ext_authz) або підставу для вужчих AuthorizationPolicy в Istio.
- Сканувати треба те, що реально запущено. Скан у CI дає лише знімок, а нові CVE з’являються в уже розгорнутих образах. Цикл «Kubernetes API → образи → Trivy» я додам як регулярну runtime-перевірку поруч з admission-контролем.
- Відносна метрика може карати за патчі. Через min-max довіра залежить від сусідів: Vul admin-order не змінився, а TM упав із 94,27 до 91,66; avatar зменшив Vul, але отримав TM = 0. Для рішень про доступ я поєднуватиму рейтинг з абсолютними порогами.

5. Висновок

Внески роботи: початкова довіра на основі вразливостей замість 100 % за замовчуванням, підвищення й зниження ТМ за станом сервісу і поширення результатів через service mesh. Обмеження: оцінено лише 5 сервісів і два знімки версій, сценарію атаки немає, зв’язок ТМ із політиками Istio не продемонстровано, ваги задаються вручну; формула оперує сумами CVSS, а приклад рахує кількість вразливостей. Автори планують автоматично оновлювати вразливі бібліотеки, прогнозувати невідомі загрози методами ML, інтегруватися із системами керування ризиками й перевірити підхід у 6G-мережах.